

Secure Software Development Lifecycle (SSDLC) & Code Review SOP

Document Code: DOC-SOP-03 | **Type:** SOP | **Current Version:** 2.0

Organization: ApexNova Global Technologies | **Department:** ENG_DEV | **Precedence Level:** 2

Version 2.0 — Dual peer reviews required, zero Critical/High SAST flaws allowed, pre-commit secret scanning, and 80% test coverage minimum.

Section 3.1: Branch Protection & Dual Peer Review

Direct pushes to main/master branches are disabled. Every pull request requires at least two approved reviews from senior engineers before merge eligibility.

Section 3.2: Automated Static Security Testing (SAST) Gates

CI/CD pipelines enforce automated SAST and dependency vulnerability scans (Snyk/SonarQube). Merges are blocked if any Critical or High security flaws are detected.

Section 3.3: Secret Scanning & Credential Exposure

Pre-commit git hooks block commits containing API keys, private certificates, or database credentials. Exposed tokens trigger immediate credential invalidation.

Section 3.4: Unit & Integration Test Coverage Threshold

All new code additions must maintain a minimum 80% automated unit and integration test coverage.